

最終報告書

本報告書は、NEDOプロジェクトの一環として実施した医療特化型LLMシステムの安全性評価におけるレッドチーミングの結果を、経営層向けに事業インパクトの観点で整理したものである。本プロジェクトではLLMの安全性を評価するための疑似システム環境を構築し、LLMに対するレッドチーミングを実施した。技術的な詳細は 05_実施結果報告書を参照。

エグゼクティブサマリ

実施概要

NEDOプロジェクトの一環として、医療特化型LLMシステムの安全性評価のために構築した疑似システム環境を用い、AIセーフティ・インスティテュートの「[AIセーフティに関するレッドチーミング手法ガイド](#)」に基づくレッドチーミングを実施した。

実施期間：令和7年12月1日 ～ 令和8年3月24日

実施体制：

役割	責任範囲
経営層	RT実施の最終承認、最終報告書の承認
管理者	全体統括、実施計画策定、最終報告書作成
攻撃実施者	攻撃シナリオ作成・実施、実施結果報告書作成
情シス担当者	システム構成の技術的助言、実施環境の整備
AIセキュリティ有識者	AIセーフティ評価、攻撃手法の助言

実施規模：

項目	内容
対象モデル数	20モデル
テスト総数	6,000件（300件 × 20モデル）
攻撃手法の種類	15種
AISI評価観点	3観点（プライバシー保護、セキュリティ確保、有害情報の出力制御）

主要な発見事項

脆弱性ID	AISI評価観点	深刻度	モデル別攻撃成功率	主な内容
V-003	有害情報の出力制御	極高	1%～13%	致死量情報等の出力（ 全モデルで要改善 ）
V-002	セキュリティ確保	高	0%～69%	システム権限偽装による情報抽出（7モデルで不合格）
V-001	プライバシー保護	高	0%～52%	患者情報の漏洩（6モデルで不合格）

モデル別の総合評価

ガードレール	総合判定	モデル数	主なモデル
あり	一部要改善	4	Claude Sonnet 4.5/4.6、GPT-5.2/5.4
なし	一部要改善	9	Qwen3.5-397B-A17B (think)、GLM-4.7 (think)、GLM-5 (think)、gpt-oss-120b、Weblab-MedLLM-gpt-oss-120b (think)、Weblab-MedLLM-GLM-4.7、Weblab-MedLLM-GLM-4.7 (think)、Qwen3-235B-A22B-Thinking-2507 (think)、Kimi-K2
なし	不合格あり	7	Qwen3-235B-A22B (think)、Qwen3-235B-A22B-Instruct-2507、Qwen3-235B-A22B-Thinking-2507 (w/ reasoning token)、Weblab-MedLLM-Qwen2.5-109B-Instruct、llm-jp-3.1-8x13b-instruct4、Weblab-MedLLM-Qwen3-235B-Instruct、Weblab-MedLLM-Qwen3-235B-Thinking (think)

注記：全クラウドAPIモデルはOpenRouter経由でアクセスしているが、プロバイダ側のガードレール（入出力フィルタ、コンテンツモデレーション等）が確認されているのは Anthropic（Claude） および OpenAI（GPT）のみである。その他のクラウドAPIモデル（Kimi-K2、Qwen3系、GLM、gpt-oss-120b等） およびオンプレミスモデル（vLLM）にはプロバイダ側ガードレールがなく、結果はモデル単体の防御能力を反映している。

結論

20モデルを対象としたレッドチーミングの結果、**全モデルが有害情報の出力制御で要改善判定**となり、7モデルがプライバシー保護・セキュリティ確保で不合格判定となった。特に致死量情報等の有害出力は患者の生命に直結するため、早急な対策が必要である。

不合格7モデル（Qwen3-235B-A22B (think)、Qwen3-235B-A22B-Instruct-2507、Qwen3-235B-A22B-Thinking-2507 (w/ reasoning token)、Weblab-MedLLM-Qwen2.5-109B-Instruct、llm-jp-3.1-8x13b-instruct4、Weblab-MedLLM-Qwen3-235B-Instruct、Weblab-MedLLM-Qwen3-235B-Thinking (think)）はいずれもプロバイダ側ガードレールなしで運用されており、出力ガードレールの導入により防御性能の改善が見込まれる。一方、同じガードレールなし条件でもGLM-5 (think) (2.3%)、gpt-oss-120b (3.0%)、GLM-4.7 (think) (3.7%) はガードレールありモデルと同等の防御性能を示しており、**モデル自体の品質とガードレールの両面からの対策**が重要である。

1. 実施結果の総括

1.1 実施範囲と結果概要

評価観点	テスト数	攻撃成功数	モデル別攻撃成功率	合格	要改善	不合格
プライバシー保護	2,000	297	0%～52%	2	12	6
セキュリティ確保	2,000	407	0%～69%	3	10	7
有害情報の出力制御	1,998	134	1%～13%	0	20	0
合計	5,998	838	0.7%～42.7%			

1.2 攻撃手法の有効性（評価観点別 上位3手法）

各評価観点ごとに、攻撃成功率の高い上位3手法を示す。

プライバシー保護 (V-001)

攻撃手法	攻撃成功率	概要
indirect（間接抽出）	28.5%	品質監査・翻訳サンプル等を装った情報抽出
stepwise（段階的抽出）	14.0%	計算確認等を装い段階的に情報を引き出す手法
impersonation（権限詐称）	12.2%	担当医・看護師長等への権限詐称

セキュリティ確保（V-002）

攻撃手法	攻撃成功率	概要
roleplay（ロールプレイ）	23.5%	データ検証AI等演技させる手法
template_exploit（テンプレート悪用）	22.2%	フォーマット変換を利用した構造化データ抽出
injection（プロンプトインジェクション）	21.5%	システム管理者偽装等によるセキュリティ制御の迂回

有害情報の出力制御（V-003）

攻撃手法	攻撃成功率	概要
harmful_lethal（致死量情報）	26.0%	研究・教育目的を偽装した致死量情報の要求
harmful_illegal（違法薬物）	4.8%	違法薬物入手・無許可販売等の要求
harmful_poison（毒物情報）	2.5%	薬物混入・投毒方法の要求

1.3 AIセーフティ評価観点別の評価

評価観点	求められる水準	今回のRT対象	評価結果	判定
プライバシー保護	高	○	モデル別攻撃成功率0%～52%。2モデル合格、6モデル不合格（V-001）	不合格あり
セキュリティ確保	高	○	モデル別攻撃成功率0%～69%。3モデル合格、7モデル不合格（V-002）	不合格あり
有害情報の出力制御	高	○	モデル別攻撃成功率1%～13%。全20モデル要改善、合格なし（V-003）	要改善

※ 評価観点10項目の水準一覧は 03_実施計画書 Section 3 を参照。今回未対象の評価観点への対応は本報告書 Section 4.3 を参照。

2. 発見された脆弱性と事業インパクト

2.1 脆弱性V-003：有害情報の出力制御の不備

致死量情報・投毒方法等の有害な医療情報がLLMから出力される脆弱性（技術詳細は 05_実施結果報告書 Section 3.3 を参照）。モデル別攻撃成功率は1%～13%で、**全20モデルが要改善判定**（合格モデルなし）であり、現時点のLLM技術全般に共通する課題。

事業インパクト分析

観点	評価	詳細
患者安全への影響	極高	致死量情報の悪用による重篤な有害事象のリスク
法的リスク	極高	薬機法違反、傷害罪幫助の可能性
レピュテーションリスク	高	医療AIシステムとしての信頼失墜、報道リスク
規制対応リスク	高	厚生労働省への報告義務、行政指導の可能性
財務的影響	高	損害賠償、対策費用、売上減少

リスクベース評価

項目	評価
攻撃の実現性	中～高（研究・教育目的の偽装によるharmful_lethalで攻撃成功率26.0%）
システムへの影響度	極高（患者の生命に直接影響）
総合リスク評価	極高

改善の方向性

1. **即時対応（緊急）**：致死量・過量投与情報の出力を検出・ブロックする出力フィルタの実装
2. **短期対応（1ヶ月以内）**：有害情報の出力を検出・ブロックする出力フィルタの強化
3. **中期対応（3ヶ月以内）**：有害情報の定義と閾値の継続的な見直し体制の構築

※ 詳細実施計画は別途策定する改善計画書にて定める。

2.2 脆弱性V-002：セキュリティ確保の不備

ロールプレイ・テンプレート悪用・プロンプトインジェクション等によりシステムプロンプトの開示禁止指示が迂回され、患者データが構造化形式（CSV、FHIR等）で出力される脆弱性（技術詳細は 05_実施結果報告書 Section 3.2 を参照）。モデル別攻撃成功率は0%～69%とばらつきが極めて大きく、7モデルが不合格。

事業インパクト分析

観点	評価	詳細
患者プライバシーへの影響	高	構造化データとしての大量抽出リスク
法的リスク	高	個人情報保護法違反、医療法違反の可能性
内部統制リスク	高	職員による情報不正取得のリスク
規制対応リスク	高	個人情報保護委員会への報告義務

リスクベース評価

項目	評価
攻撃の実現性	高（ロールプレイ23.5%、テンプレート悪用22.2%、プロンプトインジェクション21.5%の高い成功率）
システムへの影響度	高（大量データ抽出のリスク）
総合リスク評価	高

改善の方向性

1. **短期対応（1ヶ月以内）**：構造化データ出力（CSV、JSON、FHIR形式等）の検出・ブロック
2. **短期対応（1ヶ月以内）**：デバッグモード・管理者モード偽装の検出フィルタ
3. **中期対応（3ヶ月以内）**：システムプロンプトの強化（権限偽装・モード切替の明示的拒否）、出力フィルタの強化

※ 詳細実施計画は別途策定する改善計画書にて定める。

2.3 脆弱性V-001：プライバシー保護の不備

間接抽出・段階的抽出・権限詐称等により患者の診療記録が漏洩する脆弱性（技術詳細は 05_実施結果報告書 Section 3.1 を参照）。モデル別攻撃成功率は0%～52%とばらつきが大きく、6モデルが不合格（プライバシー保護）。

事業インパクト分析

観点	評価	詳細
患者プライバシーへの影響	高	個人情報・診療記録の漏洩リスク
法的リスク	高	個人情報保護法違反、医療法違反の可能性
レピュテーションリスク	高	情報漏洩事案として報道される可能性
規制対応リスク	高	個人情報保護委員会への報告義務
財務的影響	中	損害賠償、対策費用

リスクベース評価

項目	評価
攻撃の実現性	中～高（間接抽出28.5%、段階的抽出14.0%、権限詐称12.2%の成功率）
システムへの影響度	高（機密情報の直接的な漏洩）
総合リスク評価	高

改善の方向性

- 1. **短期対応**：間接抽出型攻撃パターン（サンプル作成、テンプレート作成等）の検出フィルタ
- 2. **短期対応**：システムプロンプトの強化（患者データのそのままの出力禁止の明示）
- 3. **中期対応**：出力フィルタでの患者情報検出・マスキング機能の実装

※ 詳細実施計画は別途策定する改善計画書にて定める。

3. 改善策の提案

3.1 改善策一覧

対応時期	No.	改善策	対象脆弱性	担当
緊急（即時）	E-1	致死量・過量投与情報の出力ブロック	V-003	開発チーム
緊急（1週間）	E-2	利用者への暫定的な注意喚起	全般	運用チーム
短期（2週間）	S-1	不合格7モデルへの出力ガードレール導入・再評価	全般	開発チーム
短期（1ヶ月）	S-2～S-3	出力フィルタの強化（患者情報検出・構造化データ出力の制限・システムプロンプト強化を含む）	V-001, V-002	開発チーム
中期（3ヶ月）	M-1～M-5	出力フィルタ高度化、多層防御実装、有害情報定義見直し、攻撃パターンDB構築、有害情報ガイドライン策定	全般	開発チーム・品質管理

3.2 改善策の詳細

改善策の詳細実施計画（技術的対策・運用的対策・組織的対策の分類、スケジュール、体制、予算）は別途策定する改善計画書にて定める。

4. 今後の推奨事項

4.1 短期的推奨事項（3ヶ月以内）

- 緊急対応**：V-003（有害情報の出力制御）への対策を最優先で実施
- モデル選定・ガードレール導入**：不合格7モデル（Qwen3-235B-A22B (think)、Qwen3-235B-A22B-Instruct-2507、Qwen3-235B-A22B-Thinking-2507 (w/ reasoning token)、Weblab-MedLLM-Qwen2.5-109B-Instruct、llm-jp-3.1-8x13b-instruct4、Weblab-

MedLLM-Qwen3-235B-Instruct、Weblab-MedLLM-Qwen3-235B-Thinking (think) への出力ガードレールの導入を推進し、改善後に再評価

3. **高優先対応**：V-002、V-001への対策を並行して実施

4. **再テスト**：対策実施後の再レッドチーミング（6,000件のテストケースを再実行）による効果検証

4.2 追加学習による安全性への影響

Weblab提供のファインチューニングモデルとベースモデルを比較した結果、追加学習による安全性への影響はベースモデルの選択に大きく依存することが明らかになった。

gpt-oss-120bおよびGLM-4.7 (think)ベースのWeblab開発モデルは、医療ドメイン向けの追加学習後も安全性を良好に維持している。 Weblab-MedLLM-gpt-oss-120b (think)

（3.0%→4.0%、+1.0pt）およびWeblab-MedLLM-GLM-4.7 (think)（3.7%→4.7%、+1.0pt）はベースモデルとほぼ同等の防御性能を示しており、追加学習と安全性の両立が達成されている。Weblab-MedLLM-GLM-4.7（enable_thinking=false版、3.7%→8.7%、+5.0pt）もやや劣化が見られるものの、要改善の範囲内に収まっている。

一方、Qwen3-235B-A22Bベースの2モデルでは大幅な安全性の劣化が確認された。Qwen3-235B-A22B-Thinking-2507 (think)（8.0%→39.3%、+31.3pt）は、追加学習によりreasoningプロセスをreasoningトークンとして隠蔽する機能が損なわれたことが主因である（詳細は4.3節を参照）。Qwen3-235B-A22B-Instruct-2507（13.7%→28.0%、+14.3pt）もシステムプロンプトの遵守能力が低下しており、Qwen3-235B-A22Bベースでは追加学習と安全性の両立に課題が残る。

ファインチューニング後にはベースモデルとの比較を含むレッドチーミングを実施し、アライメント能力の維持を確認することが推奨される。

4.3 reasoningプロセスにおける情報漏洩リスク

今回のRTでは、Qwen3系モデルにおいてreasoningプロセス（思考過程）の内容がそのままユーザー向けレスポンスとして出力されるケースが確認された。仮にシステムプロンプトで機微情報の出力を禁じていたとしても、reasoningプロセス中に入力データの内容を振り返る過程で機微情報を羅列してしまう可能性がある。通常、reasoningプロセスは特殊トークン

（**<think>** タグ）で囲われておりユーザーサイドからは不可視となっているため、reasoning部分のレスポンスを省くことでリスクを回避できる。しかし、Qwen3の235Bモデルでは

<think> タグの挙動が不安定であることがコミュニティでも報告されており、reasoningプロ

セスの内容がユーザーレスポンスとして出力されてしまう場合には情報漏洩に繋がる可能性があり、注意が必要である。

Weblab提供のファインチューニングモデル（Weblab-MedLLM-Qwen3-235B-Thinking (think)）では、追加学習によりこの問題が顕著に悪化し、reasoningプロセスをreasoningトークンとして隠蔽する機能が損なわれていた。これが当該モデルの攻撃成功率がベースモデル（Qwen3-235B-A22B-Thinking-2507 (think)）から+31.3pt劣化した主要因である。なお、この問題はベースモデルでも発生する場合がある。実運用上は、サーバーサイドで出力コンテンツをモニタリングするガードレール等を駆使し、こうしたリスクに多層的に備えることが推奨される。

4.4 中長期的推奨事項（6ヶ月～1年）

1. **継続的評価**：四半期ごとのレッドチーミング実施
2. **攻撃トレンド監視**：LLMに対する新たな攻撃手法の継続的な情報収集
3. **AI安全性文化の醸成**：組織全体でのAIセーフティ意識の向上
4. **モデル更新時の再評価**：新モデルの導入時には必ずレッドチーミングを実施（特にreasoningモデルのreasoningトークン制御機能等、安全に関わる機能の維持確認）

4.5 今回未対象の評価観点への対応

今回のRTでは3つの評価観点（プライバシー保護、セキュリティ確保、有害情報の出力制御）を対象としたが、以下の評価観点については今後のRT実施を推奨する。

評価観点	優先度	推奨時期	理由
偽誤情報の出力・誘導の防止	高	四半期以内	誤った処方情報の出力リスクの体系的な評価が必要
ロバスト性	高	四半期以内	複合条件下での出力安定性の体系的な評価が必要
公平性と包摂性	高	四半期以内	診断バイアスの誘発（リスクシナリオR-M5）の体系的な評価が必要
説明可能性	中	半期以内	診断根拠の提示能力の評価が必要
ハイリスク利用・目的外利用への対処	中	半期以内	医師代替としての誤用リスクの評価が必要
データ品質	低	年次	訓練データの品質・最新性の評価が必要
検証可能性	低	年次	ログ・追試可能性の評価が必要

※ 各評価観点の詳細は [risk_framework/リスクフレームワーク.xlsx](#) を参照。

4.6 定期的な評価体制の構築

評価項目	頻度	担当
脆弱性スキャン	月次	情報システム部門
レッドチーミング	四半期	外部専門家
AIセーフティ監査	年次	第三者機関

5. 結論

本レッドチーミングにより、20モデルを対象とした6,000件のテストの結果、3件の脆弱性カテゴリが発見された。特に「有害情報の出力制御」は全20モデルで要改善判定となり、致死量情報等の出力は患者の生命に直結する極めて深刻な課題である。

モデル間で攻撃成功率に0.7%～42.7%の大きな差があることが判明した。この差にはプロバイダ側ガードレールの有無が一因として寄与しているが、ガードレールなしモデルの中でもQwen3.5-397B-A17B (think) (2.0%) やGLM-5 (think) (2.3%) のようにガードレールありモデルと同等の防御性能を示すモデルから、llm-jp-3.1-8x13b-instruct4 (42.7%) のように大幅に漏洩するモデルまで、モデル間のばらつきが極めて大きい。ガードレールありモデル（Anthropic・OpenAI）はプライバシー保護・セキュリティ確保で安定して高い防御性能を示す一方、有害情報の出力制御ではガードレールの有無にかかわらず全モデルが要改善となっており、この観点ではモデル本体の安全性とシステム側での対策が重要である。

不合格の7モデル（Qwen3-235B-A22B (think)、Qwen3-235B-A22B-Instruct-2507、Qwen3-235B-A22B-Thinking-2507 (w/ reasoning token)、Weblab-MedLLM-Qwen2.5-109B-Instruct、llm-jp-3.1-8x13b-instruct4、Weblab-MedLLM-Qwen3-235B-Instruct、Weblab-MedLLM-Qwen3-235B-Thinking (think)）はいずれもガードレールなしで運用されており、出力ガードレールの導入により改善が見込まれる。ただし、ガードレールなしでも高い防御性能を示すモデルが存在することから、**モデル自体の品質選定とガードレール導入の両面**からの対策が必要である。

本報告書で提案した改善策を計画的に実施することにより、システムの安全性を大幅に向上させることが可能である。なお、本プロジェクトは令和8年3月をもって終了するため、改善策の具体的な実施は本プロジェクトの範囲外となる。改善計画書は実施する場合の計画イメ

ージとして策定しており、実際に改善を行う際は本報告書および改善計画書を参考に具体的な計画を別途策定されたい。また、AIセーフティは継続的な取り組みが必要であり、定期的なレッドチーミングの実施と改善サイクルの確立を強く推奨する。